

Zastosowania algorytmów kryptograficznych

Podpisy cyfrowe

Podpisy cyfrowe

- ❑ Są to środki mające na celu zapewnienie identyfikacji źródła komunikatu (autentyczność wiadomości)
- ❑ Zazwyczaj używane są do tego kryptograficzne algorytmy asymetryczne
 - ✓ nadawca komunikatu podpisuje go przy użyciu klucza prywatnego
 - ✓ podpis weryfikuje się poprzez zastosowanie klucza publicznego
- ❑ Podpisanie wiadomości m przez użytkownika A polega na jej przekształceniu **przy użyciu klucza prywatnego** D_A (operacja odszyfrowania)
- ❑ Komunikat m podpisany przez A zapisujemy jako $S_A(m)$

111

Podpisy cyfrowe

- ❑ Weryfikacja podpisu polega na zaszyfrowaniu go **publicznym kluczem strony podpisującej** E_A i sprawdzeniu czy uzyskano tę samą wiadomość m :

$$E_A(D_A) = m$$

- ❑ Komunikat m podpisany przez A zapisujemy jako $S_A(m)$
- ❑ Problemem może być zapewnienie autentyczności klucza publicznego używanego do weryfikacji podpisu
 - ✓ Problem ten w praktyce rozwiązywany jest poprzez zastosowanie certyfikatów cyfrowych

112

Certyfikaty cyfrowe

- ❑ Certyfikat jest połączeniem pewnej nazwy A oraz klucza publicznego E_A , wspólnie podpisanym przez zaufaną stronę trzecią T :

$$S_T(A, E_A)$$

- ❑ Weryfikacja tego podpisu wymaga użycia klucza publicznego strony T , co z kolei może wymagać podpisu kogoś jeszcze bardziej zaufanego itd.:

$$S_{T_1}(A, E_A)$$

$$S_{T_2}(T_1, E_{T_1})$$

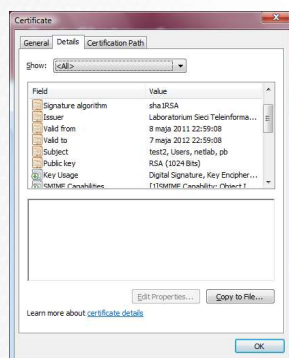
$$S_{T_3}(T_2, E_{T_2})$$

- ❑ Zaufana (wiarygodna) strona nazywana jest zwykle ośrodkiem certyfikacyjnym (CA - *Certificate Authority*), a hierarchia podpisów kluczy przez kolejne CA określana jest jako infrastruktura klucza publicznego (PKI - *Public Key Infrastructure*)

113

Certyfikaty cyfrowe

- ✓ Certyfikat może również zawierać dodatkowe informacje (takie jak data ważności klucza publicznego, wersje zastosowanych algorytmów i wiele innych)



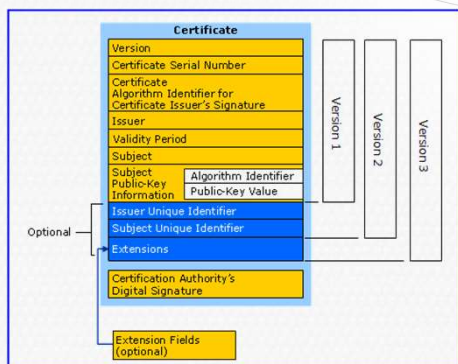
114

Infrastruktura PKI

- ❑ W praktycznych infrastrukturach PKI certyfikaty obsługiwane są zgodnie ze standardem X.509 (ITU-T), który definiuje m.in.:
 - ✓ certyfikaty klucza publicznego (PKC - *Public Key Certificate*)
 - ✓ listy certyfikatów unieważnionych (CLR - *Certificate Revocation List*)
 - ✓ certyfikaty atrybutu (AC - *Attribute Certificate*) wiążące tożsamość danego podmiotu z określonymi atrybutami (w praktyce poświadczają one uprawnienia danego podmiotu do wykonywania określonych operacji)
 - ✓ algorytm weryfikacji ścieżki certyfikatów
- ❑ Specyfikacja X.509 dostępna jest pod adresem: <http://www.itu.int/rec/T-REC-X.509/en>

115

Format certyfikatu X.509

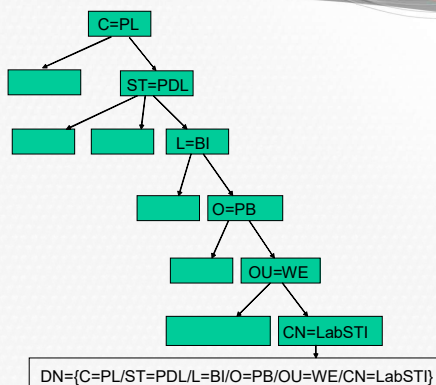


Certyfikat X.509

□ W certyfikatach X.509 nazwy podmiotów (np. właściciela certyfikatu oraz wystawiającego certyfikat) zapisywane są jako jednoznaczne nazwy DN (*Distinguished Name*) mające strukturę hierarchiczną (słów kluczowych jest więcej niż w poniższej tabelce)

Keyword	Meaning
C	Country
ST	State
L	Locality name
O	Organization name
OU	Organization Unit name
CN	Common Name

Certyfikat X.509



Certyfikat X.509

[illegible]

Bezpieczne funkcje skrótu

- ☐ Podpisanie całej wiadomości pewnym kluczem daje w efekcie podpis o wielkości takiej samej jak wiadomość
 - podwojenie wolumenu przesyłanych danych
- ☐ Dlatego korzystniej jest podpisywać jedynie pewną wartość będącą czymś w rodzaju streszczenia lub skrótu wiadomości
- ☐ Aby podpis był wiarygodny wyznaczony skrót wiadomości powinien w sposób wystarczająco pewny identyfikować tę wiadomość
- ☐ Skróty wiadomości wyznacza się przy użyciu tzw. bezpiecznych funkcji skrótu (*Secure Hash Function*)

Bezpieczne funkcje skrótu

- ❑ Są to funkcje jednokierunkowe, zwracające na podstawie ciągu wejściowego ciąg wyjściowy o stałej (zazwyczaj dużo mniejszej niż ciąg wejściowy) długości rzędu 128 - 512 bitów
- ❑ Są one konstruowane jako funkcje pseudolosowe, w których dowolna wartość skrótu jest jednakowo prawdopodobna.
 - ✓ W żaden dostrzegalny sposób wartość wyjściowa nie powinna być zależna od ciągu wejściowego.
 - ✓ Pojedyncza zmiana dowolnego bitu w ciągu wejściowym powinna powodować zmianę przeciętnie połowy bitów wyjściowych.

$$h = H(m)$$

h – liczba o długości n będąca skrótem wiadomości m

$H(m)$ – funkcja skrótu

Bezpieczne funkcje skrótu

- ❑ Wymagane cechy funkcji $H(m)$:
 - ✓ mając dane m , łatwo jest obliczyć h
 - ✓ mając dane h , trudno jest obliczyć m
 - ✓ mając dane m , trudno jest znaleźć inną wiadomość m' taką, że $H(m)=H(m')$
- ❑ Określenie „trudny” oznacza konieczność wykonania operacji wymagających wystarczająco długiego czasu (np. dłuższego niż ważność tej wiadomości)
 - ✓ Obecnie można przyjąć, że słowo „trudny” oznacza konieczność wykonania co najmniej 2^{64} operacji

122

Funkcje skrótu – metody ataku

- ❑ Istnieją dwa podstawowe rodzaje ataków na jednokierunkowe funkcje skrótu:
 - ✓ atak bezpośredni
 - ✓ atak metodą dnia urodzin

123

Funkcje skrótu – metody ataku

- ❑ Atak bezpośredni:
 - ✓ znalezienie dla dowolnej wiadomości takiej wiadomości m' , że $H(m')=H(m)$
 - ✓ jeżeli $m' \neq m$, to jest to tzw. kolizja funkcji skrótu
 - ✓ udany atak bezpośredni oznacza pełną utratę funkcjonalności funkcji skrótu
 - ✓ dla dobrych funkcji wymaga on wykonania średnio 2^{n-1} operacji, gdzie n jest długością skrótu wiadomości

124

Funkcje skrótu – metody ataku

- ❑ Atak metodą dnia urodzin:
 - ✓ wykorzystuje właściwość tzw. paradoksu dnia urodzin
 - ✓ polega na znalezieniu pary m i m' , takiej że $H(m)=H(m')$
 - ✓ w istocie jest to znajdowanie kolizji w funkcjach skrótu
 - ✓ pozwala na zredukowanie liczby obliczeń $2^{n/2}$ razy
- ❑ Atak metodą dnia urodzin stanowi ogromne ułatwienie
 - ✓ Dysponując maszyną wyliczającą milion skrótów 64-bitowych na sekundę atak bezpośredni zająłby 600 000 lat, podczas gdy atak urodzinowy tylko około 1 godziny!!!
- ❑ Przykład wykorzystania ataku urodzinowego do utworzenia dwóch wersji podpisanego dokumentu

125

Funkcje skrótu – sposoby użycia

- ❑ Dowolną technikę podpisu cyfrowego można zastosować w stosunku do skrótu wiadomości zamiast do całej wiadomości (wyliczenie np. RSA dla dużego bloku może być czasochłonne)
 - ✓ wówczas A przesyła do B wiadomość m oraz podpis jej skrótu $S_A(H(m))$
 - ✓ jeżeli dodatkowo wymagane jest zapewnienie poufności, to A szyfruje wiadomość m algorytmem symetrycznym z kluczem K i przesyła do B następujący zestaw: $E_B(K)$, $E_K(m)$, $S_A(H(m))$
 - ✓ Jeżeli zamiast powyższego zestawu wysłane zostanie: $E_B(K)$, $E_K(m, S_A(H(m)))$ to dodatkowo zaszyfrowane zostanie pochodzenie (podpis) wiadomości
 - ✓ aby uchronić się przed skutecznym atakiem urodzinowym należy stosować funkcje dające wynik co najmniej 128-bitowy

126

Funkcje skrótu – sposoby użycia

- ❑ Uwierzytlenie wiadomości (bez osobnego podpisu)
 - ✓ na początku wiadomości dołącza się (wspólny dla obu stron) tajny klucz K , a następnie wylicza funkcję $H(m, K)$ otrzymując tzw. kod uwierzytelniający (MAC – Message Authentication Code)
 - ✓ praktycznym zastosowaniem tego rozwiązania jest uwierzytlenie typu wezwanie-odpowiedź bez użycia algorytmu szyfrującego
 - ✓ Tradycyjnie na wezwanie C_A wysłane od A do B strona B odpowiada przy użyciu $E_K(C_A)$. Wymaga to użycia przekształcenia szyfrującego E_K , które może być licencjonowane lub podlegać ograniczeniom eksportowym
 - ✓ Ten sam efekt można uzyskać odsyłając skrót $H(C_A, K)$
- ❑ W praktyce stosowana jest, jako bezpieczniejsza, wersja o nazwie HMAC, zdefiniowana w RFC 2104 – HMAC: Keyed-Hashing for Message Authentication
- ❑ HMAC wyliczany jest jako $H(K', H(K'', C_A))$, gdzie K' i K'' są dopełnionymi wersjami tajnego klucza (RFC2104)

127

Funkcje skrótu – przykłady

- ❑ SHA-1 (*Secure Hash Algorithm*) – RFC 3174
 - ✓ zaprojektowany przy współudziale NSA
 - ✓ wytwarzane są skróty 160-bitowe
 - ✓ od 2005r. znana jest metoda pozwalająca znaleźć kolizję w 2^{63} krokach (zamiast 2^{80})
 - ✓ SHA-1 nie jest zalecany do stosowania w nowych aplikacjach
- ❑ SHA-2
 - ✓ może generować skróty o długości 224, 256, 384 lub 512 bitów
 - ✓ specyfikacja w dokumencie FIPS-140-2 (Federal Information Processing Standards)
- ❑ RIPEMD-160
 - ✓ zaprojektowany w 1996r. w środowisku akademickim
 - ✓ generuje skróty 160-bitowe
 - ✓ dotychczas nie znaleziono kolizji ani innych słabych punktów
 - ✓ zaaprobowany przez ISO i IEC w ISO/IEC 10118-3:2004

128

Funkcje skrótu – przykłady c.d.

- ❑ Whirlpool
 - ✓ obecnie używana jest wersja 3 zaaprobowana przez ISO i IEC w standardzie ISO/IEC 10118-3:2004
 - ✓ generuje skróty 512-bitowe
- ❑ MD5 (Message-Digest algorithm 5)
 - ✓ opracowany przez Ronalda Rivesta w 1991r.
 - ✓ opublikowany w RFC 1321 (1992)
 - ✓ generuje skróty 128-bitowe
 - ✓ w latach 2004-2005 kolejno publikowano metody pozwalające na coraz szybsze znalezienie kolizji w MD5 (ostatnia z nich robi to w minutę)
- ❑ MD4
 - ✓ RFC 1320 (1992)
 - ✓ kolizje możliwe do znalezienia w czasie poniżej 1 sekundy

129

Prezentacja podpisu oraz kolizji w funkcjach skrótu

Oprogramowanie CrypTool (<http://www.cryptool.org>)

Zastosowania algorytmów kryptograficznych

Podpisy cyfrowe – Infrastruktura PKI w Polsce

Infrastruktura PKI w Polsce

- ❑ W Polsce kwalifikowany podpis elektroniczny został wprowadzony na mocy ustawy z dnia 18 września 2001 r. (Dz. U. Nr 130, poz. 1450).
 - ✓ Ustawa ta została uchylona poprzez ustawę z dnia 5 września 2016 roku o usługach zaufania oraz identyfikacji elektronicznej (Dz. U. poz. 1579)
 - ❖ Dostosowuje to ustawodawstwo polskie do rozporządzenia Parlamentu Europejskiego i Rady (UE) nr 910/2014 z dnia 23 lipca 2014 r. w sprawie identyfikacji elektronicznej i usług zaufania w odniesieniu do transakcji elektronicznych na rynku wewnętrznym (rozporządzenie eIDAS - *electronic identification and trust services*, obowiązujące od 1 lipca 2016)

132

Infrastruktura PKI w Polsce

- ❑ Na mocy ustawy z 2001r. Narodowy Bank Polski został upoważniony do wykonywania czynności związanych z zarządzaniem infrastrukturą klucza publicznego (PKI) w Polsce (jest to funkcja tzw. podmiotu upoważnionego).
 - ✓ Do 22 sierpnia 2005r. funkcję tę pełniło Centrum Zaufania i Certyfikacji CENTRAST S.A., postawione w stan likwidacji. Certyfikaty wystawione przez CZIC CENTRAST S.A. zachowały ważność tak jak były wystawione, czyli do 14 grudnia 2013r.

133

Infrastruktura PKI w Polsce

Bezpieczeństwo
systemów
informatycznych

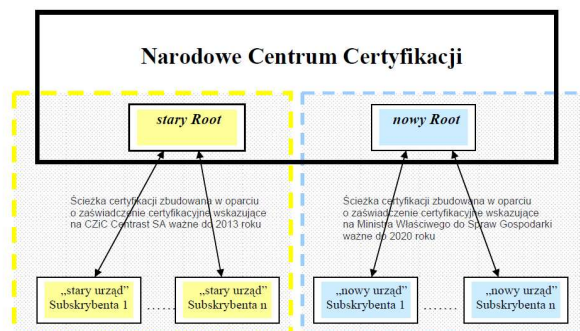
- ❑ Funkcję głównego urzędu certyfikacji pełni obecnie Narodowe Centrum Certyfikacji (www.nccert.pl) powołane przez NBP w 2005 roku.
 - ✓ Zajmuje się ono m.in. podpisywaniem certyfikatów dla urzędów certyfikacji niższego poziomu, które wystawiają certyfikaty klientom końcowym.
 - ✓ Pierwsze klucze NCCert zostały wygenerowane w 2009 roku i są one ważne do 27 października 2020.
 - ❖ Korzystają one z funkcji skrótu SHA-1 oraz algorytmu RSA z kluczem o długości 2048 bitów
 - ✓ W 2016 zostały wygenerowane kolejne klucze NCCert z datą ważności do 10 grudnia 2039.
 - ❖ Korzystają one z funkcji skrótu SHA-512 oraz algorytmu RSA z kluczem o długości 4096 bitów

134

Infrastruktura PKI w Polsce

Bezpieczeństwo
systemów
informatycznych

Dwie „stare” ścieżki certyfikacji w ramach krajowej infrastruktury klucza publicznego



135

Infrastruktura PKI w Polsce

Bezpieczeństwo
systemów
informatycznych

- ❑ Warunki techniczne dla podmiotów i urzędów uczestniczących w procesie wystawiania certyfikatów oraz składania i weryfikacji podpisów elektronicznych określone są Rozporządzeniem Rady Ministrów z dnia 7 sierpnia 2002r.
 - ❑ Aktualnie jest to Rozporządzenie Ministra Cyfryzacji z dnia 6 października 2016 r. w sprawie krajowej infrastruktury zaufania.
- ❑ Zgodnie z tym Rozporządzeniem podpisy kwalifikowane muszą być realizowane m.in. poprzez:
 - ✓ komponent techniczny — sprzęt stosowany w celu wygenerowania lub użycia danych służących do składania bezpiecznego podpisu elektronicznego lub poświadczenia elektronicznego
 - ✓ bezpieczne urządzenie do składania podpisów elektronicznych, które składa się z oprogramowania podpisującego oraz współpracującego z nim komponentu technicznego.

136

Infrastruktura PKI w Polsce

Bezpieczeństwo
systemów
informatycznych

- ❑ Warunki dla komponentu technicznego określone przez Rozporządzenie RM

✓ „Bezpieczne urządzenie do składania podpisów elektronicznych oraz bezpieczne urządzenie do weryfikacji podpisów elektronicznych powinno uniemożliwiać odtworzenie jakichkolwiek danych, których ujawnienie może spowodować brak skuteczności mechanizmów zabezpieczających, w szczególności hasła i danych służących do składania bezpiecznego podpisu elektronicznego, zawartych w komponencie technicznym, na podstawie obserwacji i pomiarów zewnętrznych zjawisk fizycznych związanych z przechowywaniem i użytkowaniem komponentu technicznego.”

137